Rapport de TP2

APIs, Fiabilité et Sécurité

HOUDA FETTOUH

1 Introduction

Ce TP consiste à concevoir un système de gestion documentaire distribué en définissant :

— un contrat d'API
— des politiques de fiabilité
— une stratégie de sécurité

2 L1 — Contrat d'API

Endpoint	Méthode	Entrée	Sortie	Erreurs	Idempotent
/api/v1/auth/log	nPOST	username, password	token, expires_at	400, 401, 429	Non
/api/v1/auth/ver	ifyGET	Header token	valid, user_id	401	Oui
/api/v1/documen	tsPOST	title, content	id, created_at	400, 401, 403	Non (clé)
/api/v1/documen	tsGET	page, per_page	data, total	400, 401	Oui
/api/v1/documen	ts/idGET	id	document	404, 401	Oui
/api/v1/documen	ts/idPUT	title, content	updated_at	400, 404	Oui
/api/v1/documen	ts/idDELETE	id	—	404, 401	Oui
/api/v1/search	GET	query, page	results	400, 429	Oui

2.1 Remarques

— Utilisation de JSON
— Pagination obligatoire (max 100)
— UUID pour les identifiants
— Idempotency-Key pour POST

3 L2 — Politiques de Fiabilité

3.1 Paramètres par service

Service	Timeout	Retry	Backoff	Idempotence
Auth login	5s	1	1s	Non
Auth verify	3s	2	0.5s	Oui

Documents GET	10s	2	exponentiel	Oui
Documents POST	15s	0	—	Oui (clé)
Search	8s	2	exponentiel + jitter	Oui

3.2 Analyse des scénarios

Scénario	Risque	Politique	Justification
Latence élevée	blocage + mauvaise UX	timeout + circuit breaker	évite effet cascade
Serveur intermittent	erreurs aléatoires	retry + backoff + jitter	tolère erreurs temporaires
Duplication	double création	Idempotency-Key	évite duplication

4 L3 — Matrice de Sécurité

Surface	Menace	Contrôle	Priorité
/auth/login	brute force	rate limiting + verrouillage	Critique
/documents POST	injection JSON	validation stricte	Critique
/search	DDoS	pagination + rate limiting	Élevée
Tous endpoints	MITM	HTTPS obligatoire	Critique
Inter-services	usurpation	mTLS / token service	Élevée
Admin	accès non autorisé	AuthZ + MFA	Critique

4.1 Gestion des tokens

— Génération : token aléatoire sécurisé
— Transmission : header Authorization
— Vérification : Auth Service
— Expiration : courte durée + refresh

5 Conclusion

Ce TP met en évidence :
— l'importance d'un contrat API clair
— la nécessité de gérer la fiabilité (timeouts, retries)
— les enjeux critiques de la sécurité (auth, validation, rate limiting)